

Tze Hui Liew (corresponding author)
Faculty of Information Science and Technology, Multimedia University
Melaka, Malaysia
thliew@mmu.edu.my

September 30, 2026

The Editor-in-Chief
Journal of Systems and Software

Transferred submission of a research paper: “It Is Not the Signature: An Empirical Study of a Hidden Key-Parse Cost in JSON Web Token Validation”

Dear Editor,

We submit the above manuscript for consideration as a research paper in the *Journal of Systems and Software* (JSS). It comes to JSS through Elsevier’s Article Transfer Service, following a scope decision at the *Journal of Information Security and Applications*, which suggested JSS as a suitable venue. The manuscript has since been substantially revised for a software-engineering readership; the files attached to this submission replace those of the earlier version.

The paper is an empirical study of performance attribution in a widely used software library. Developers usually attribute the per-request cost of JSON Web Token validation to cryptography and optimise or relocate it on that basis. We show that in `jsonwebtoken`, a widely used Node.js library, the signature is under a tenth of the validation cost. The main contributions are:

- **Root cause.** Two independent decompositions locate 60% of the cost in a discarded attempt to parse the shared secret as an asymmetric key, a failing parse used as a type test on every call.
- **A transitive dependency sets its price.** Issued from C against eight identically built OpenSSL releases, the same calls cost 394.4 μ s on 3.0.16 and 8.447 μ s on 3.5.8, so a base-image change alters the cost by more than an order of magnitude without any change to application code.
- **Real-system and ecosystem evidence.** The OpenSSL 3.0 price persists in the Node.js that Ubuntu 24.04 ships; in a containerised service, cgroup CPU accounting attributes about half of the application’s processor time per request to validation; among seven JWT libraries in four languages only this one uses a failing parse; and none of 327 sampled public call sites uses the pattern that avoids it.
- **A safe fix.** The obvious optimisation fails the library’s own key-confusion tests, because the parse is coupled to a security check. A fix that dispatches on the key material alone passes the library’s full suite on four runtimes, behaves identically to the stock library in every case we tested, and removes the parse for every token verified with a string secret, including forged ones. We derive guidance for developers, library authors and performance engineers.

We believe the work suits JSS because it combines rigorous performance measurement, root-cause analysis in a real library, a cross-ecosystem comparison and a mining study of public code, and turns them into actionable engineering guidance. In line with the journal’s open science policy, every number in the paper is generated from committed data in an open replication package (doi:10.5281/zenodo.23011153). The defect has been reported to the library maintainers (auth0/node-jsonwebtoken issue #1046); at the time of submission the pull request opened in response had not been merged.

This manuscript is original, has not been published previously, and is not under consideration for publication elsewhere. All authors have approved the manuscript and agree with its submission. The authors declare no competing interests. The use of generative AI in preparing the manuscript is declared in the manuscript.

Thank you for considering our submission.

Yours sincerely,

Tze Hui Liew, on behalf of all authors
Jannatul Ferdous Katha, Tasmia Tahmid Prova, Md Kishor Morol, Tze Hui Liew, Dip Nandi